

Security Review: CloudFront Log Exposure

`send.sgraph.ai`

Date: 2026-02-28

Reviewer: External AI-assisted review


(conversation-based assessment)





Low-risk operational metadata exposure

This event does not qualify as a security incident.

- User data remains fully secure.
- Cryptographic models are uncompromised.
- No incident escalation or user notification is required.

Assessment parameters and scope of review

This evaluation determines whether publicly shared CloudFront log data constitutes a security or privacy incident for the SG/Send platform.



A direct sample of actual CloudFront logs.



Clarifications provided by a core project contributor.



The architectural model of the SG/Send platform.



The baseline assumption that underlying encryption is cryptographically sound.

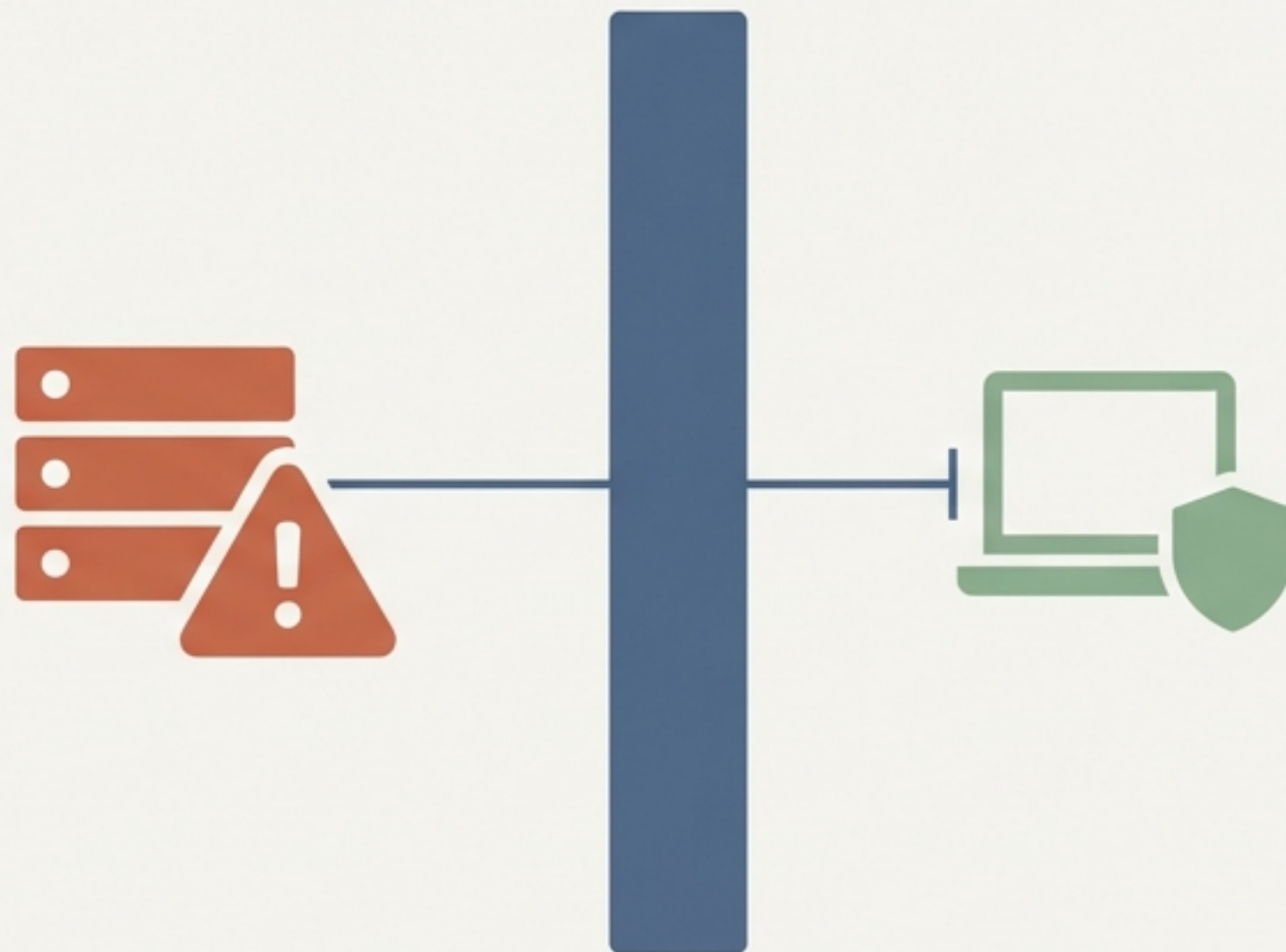
The threat model explicitly assumes total server compromise

The design goal of SG/Send is zero user impact, even if the backend is completely breached.

Inter

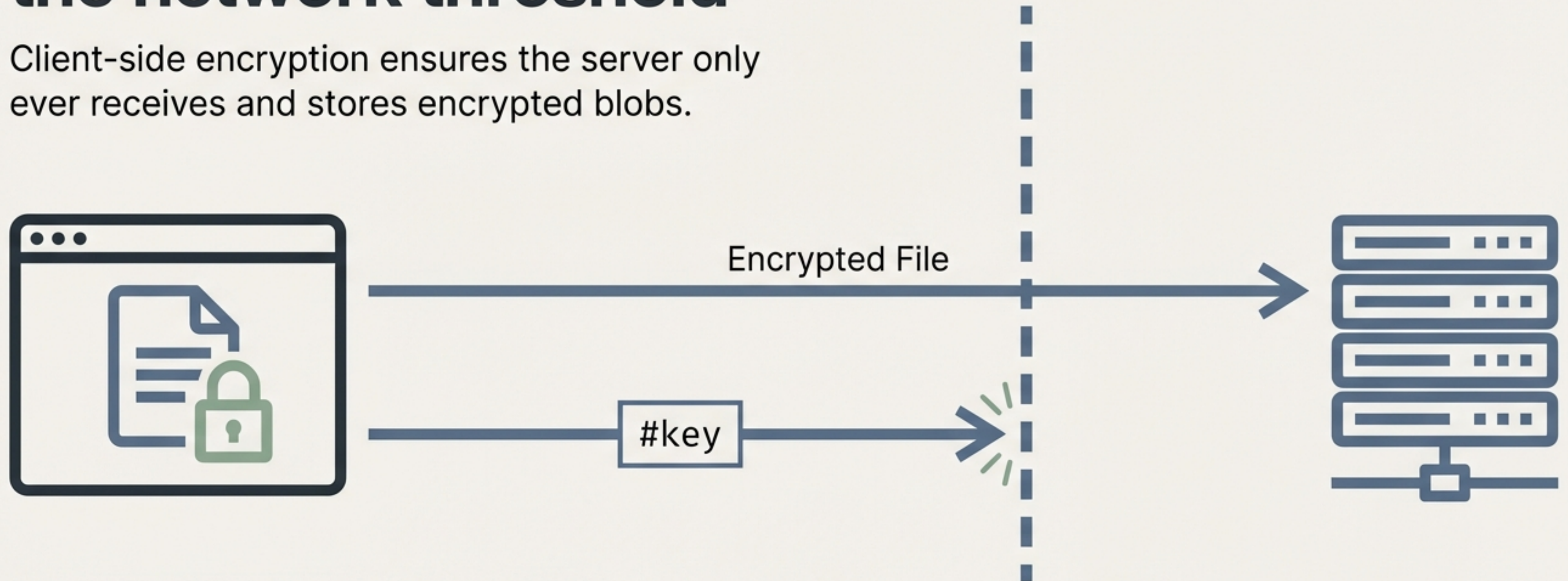
Core Assumptions Engineered into the Platform:

- The server will eventually be compromised.
- All stored files (ciphertext) may be exposed.
- All system logs may be exposed.



Decryption keys never cross the network threshold

Client-side encryption ensures the server only ever receives and stores encrypted blobs.



- Files are encrypted locally in the browser.
- The decryption key is passed exclusively via the URL fragment (#key).
- URL fragments are never transmitted in HTTP requests to the server.

Edge logging configuration deliberately drops sensitive inputs

The CloudFront configuration is strictly minimised to capture only essential routing data.

- Client IP (c-ip) is deliberately excluded.
- No request bodies are logged.
- No query strings are logged.
- No cookies are logged.
- No authorisation headers are logged.



The exposed logs capture only operational metadata



Routing

Hostnames:
`send.sgraph.ai`,
`admin.send.sgraph.ai`

Endpoint paths (e.g.,
`/transfers/complete/{id}`)



Network

HTTP methods (GET, POST)

Status codes (200, 307)

TLS version and cipher

Response sizes



Telemetry

Timestamps (high precision)

User agents

Edge locations (e.g., LHR5,
ORD56)

Country codes (e.g., IE, US,
GB)

Critical privacy and security vectors are entirely absent

The absence of this data significantly lowers security and privacy risk.

~~192.168.x.x~~

Client IP addresses



Email addresses &
Account identifiers



Authorisation headers
& Bearer tokens



Session cookies



AWS credentials



Presigned S3 URLs



Encryption keys

Transfer IDs expose no user data without client keys

Risk Level: Low

Example: 7a79bfaeaba9



- These identifiers point exclusively to encrypted blobs stored on the server.
- They are assumed to be randomly generated and non-guessable.
- Without the browser-held decryption key, they do not enable data access.

Promotional tokens are capped, monitored, and revocable

Risk Level: Low

Example: eap-feb-w4

- These are public-ish promotional tokens, intentionally shared.
- Usage is capped and monitored in real time.
- They are revocable at any time.
- Worst-case scenario is allocation exhaustion, not privilege escalation or unintended data access.



Usage Capped



Revocable

Telemetry and payload sizes remain strictly anonymous

Risk Level: Low

User Agents & Country Codes

- No IP addresses are present, no accounts are linked, and no emails are exposed. This constitutes pure anonymous telemetry.

Response Sizes

- Encrypted payload size may be inferred from response size.
- Ciphertext length does not weaken properly implemented encryption.



The exposure fails all thresholds for a reportable data breach

- ✓ No credentials were exposed.
- ✓ No personal data was exposed.
- ✓ No encryption keys were exposed.
- ✓ No presigned URLs were exposed.
- ✓ No sensitive headers or bodies were exposed.

Conclusion: This event does not meet the threshold of a security incident.

The secure-by-design architecture worked exactly as intended

In a traditional server-side encryption model, log exposure could materially increase risk. However, because SG/Send stores only ciphertext, excludes keys from the backend, and scrubs logs of personal data, this exposure does not materially affect user security.

Publishing this log data:

- Does not compromise user security or weaken cryptography.
- Introduces no meaningful attack surface.

